HACKTHEBOX

WRITE-UP

Maquina Jerry

Autor: Aarón Ibarra

Fecha: 18 de Noviembre de 2025

Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Enumeración de servicios 3

3. Explotación **4**

1. Introducción

1.1. Antecedentes

Jerry es una maquina clásica de **HackTheBox** diseñada para quienes están comenzando en el hacking ético. Clasificada como Fácil, esta máquina se centra en la explotación de un servidor Apache Tomcat mal configurado, lo que permite al atacante aprovechar credenciales por defecto y acceder al Manager App del servidor. A partir de este acceso, el usuario puede desplegar un archivo .war malicioso para lograr ejecución remota de código y finalmente obtener una shell en el sistema.

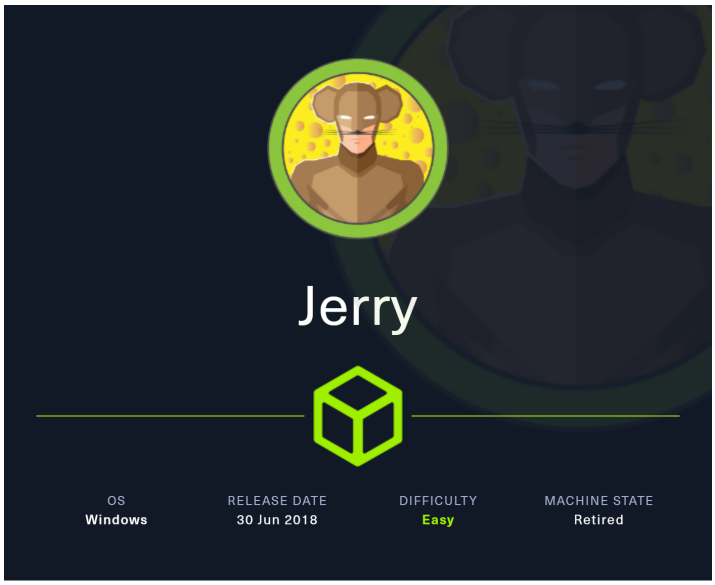

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/jerry

1.2. Objetivos

En este ejercicio se pretende recorrer todo el ciclo de un ataque, desde la enumeración inicial hasta conseguir acceso con privilegios elevados.

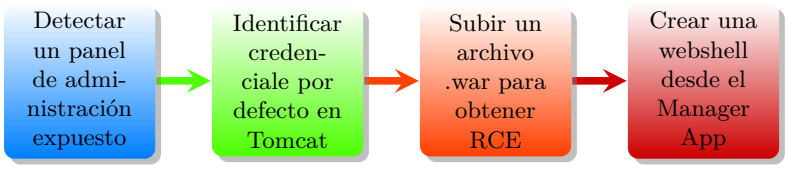

Figura 2: Fases del ataque realizadas en la máquina Jerry.

2. Enumeración

2.1. Reconocimiento inicial

Se inició un análisis preliminar para comprobar la accesibilidad del sistema objetivo desde la máquina atacante, empleando la herramienta `ping` para enviar paquetes ICMP y confirmar la conexión del equipo en la red.

```
❯ ping -c 3 10.10.10.95
PING 10.10.10.95 (10.10.10.95) 56(84) bytes of data.
64 bytes from 10.10.10.95: icmp_seq=1 ttl=127 time=82.2 ms
64 bytes from 10.10.10.95: icmp_seq=2 ttl=127 time=82.4 ms
64 bytes from 10.10.10.95: icmp_seq=3 ttl=127 time=76.5 ms

--- 10.10.10.95 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2010ms
rtt min/avg/max/mdev = 76.461/80.353/82.370/2.752 ms
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

Tras localizar el sistema se realizó un escaneo de puertos con la herramienta `nmap` con el fin de identificar los servicios en ejecución y las versiones asociadas, registrándose los siguientes hallazgos.

```
❯ sudo nmap -p- -T4 -Pn --open -sS -n --min-rate 5000 10.10.10.95
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-17 20:25 CST
Nmap scan report for 10.10.10.95
Host is up (0.24s latency).
Not shown: 65534 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
8080/tcp open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 27.35 seconds
```

Figura 4: Escaneo inicial de puertos con nmap.

2.2. Enumeración de servicios

A continuación, se procedió a una enumeración más detallada de los servicios identificados en el escaneo inicial, con el fin de obtener información adicional sobre sus configuraciones y posibles vulnerabilidades asociadas.

```
❯ nmap -p 8080 -Pn -sCV 10.10.10.95
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-17 20:27 CST
Nmap scan report for 10.10.10.95
Host is up (0.080s latency).

PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/7.0.88
|_http-favicon: Apache Tomcat

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.60 seconds
```

Figura 5: Enumeración detallada de los servicios con nmap.

3. Explotación

Después de la enumeración inicial, se identificó que el servidor exponía un servicio web en el puerto 8080, correspondiente a Apache Tomcat. Al acceder a dicho puerto, el servidor respondió con la siguiente página.

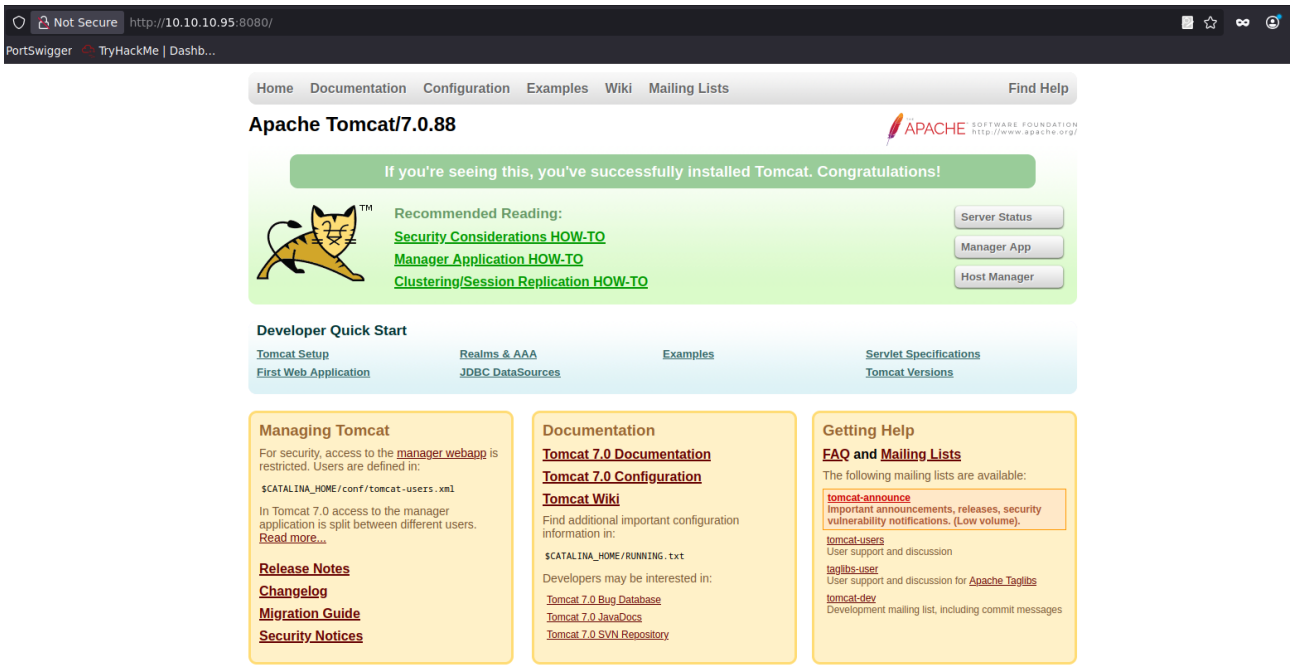

Figura 6: Página de inicio del servidor Apache Tomcat.

Posteriormente, se exploraron las distintas aplicaciones web desplegadas en el servidor, encontrándose la aplicación Manager App, que permite la gestión de aplicaciones web en Tomcat. Al intentar acceder a esta aplicación, se solicitó autenticación mediante un formulario de login.

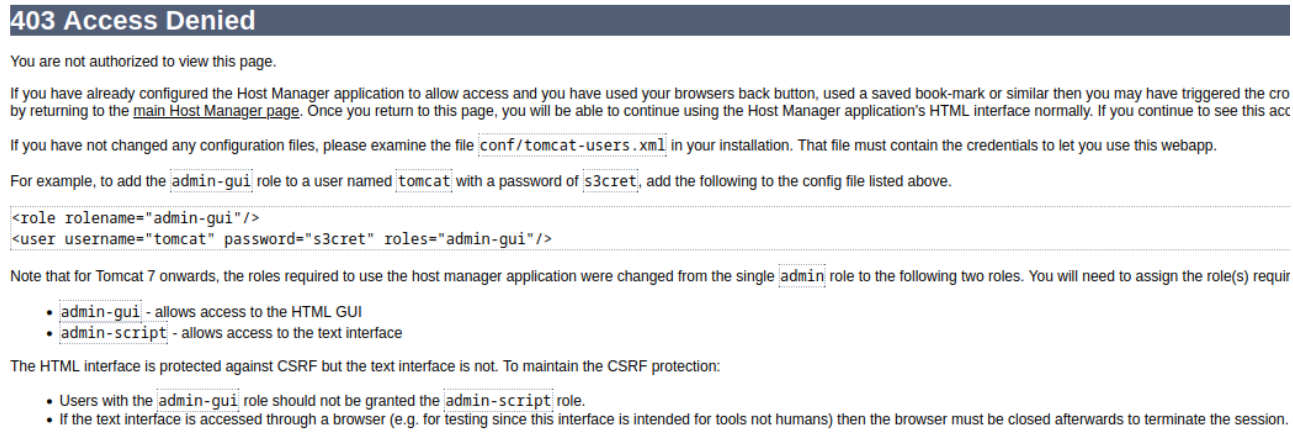

Figura 7: Intento de acceso al Manager App sin credenciales.

Dado que Tomcat suele mantenerse con configuraciones inseguras, se probaron credenciales por defecto como admin:admin y tomcat:tomcat. Finalmente, el acceso al Manager App se consiguió con las credenciales tomcat:s3cret.

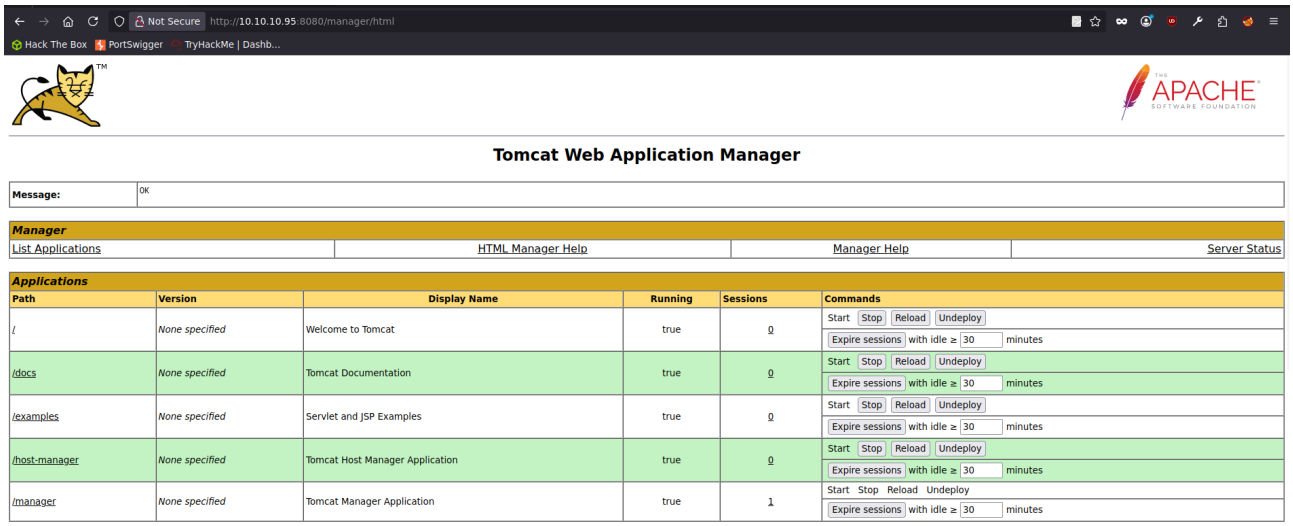

Figura 8: Acceso exitoso al Manager App con credenciales por defecto.

Con acceso al Manager App, se procedió a desplegar un archivo .war malicioso para lograr ejecución remota de código (RCE) en el servidor. Se utilizó la herramienta `msfvenom` para generar un payload adecuado, que fue empaquetado en un archivo .war listo para ser subido al servidor.

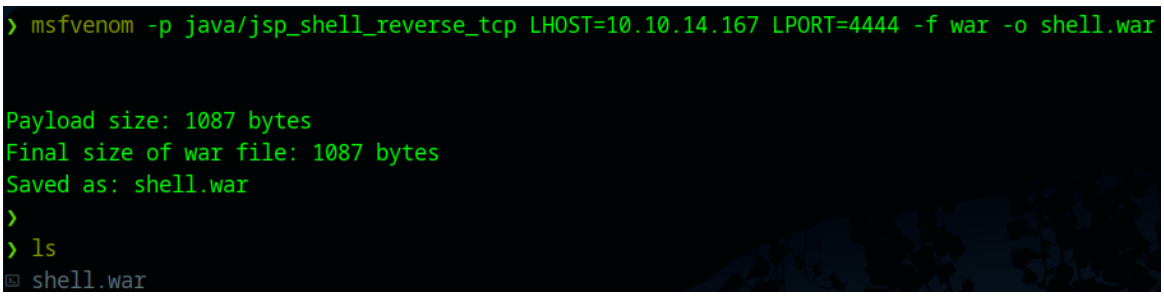

Figura 9: Generación del archivo .war malicioso con msfvenom.

—

Finalmente, se subió el archivo .war a través del Manager App y se inició un listener en la máquina atacante para capturar la conexión inversa. Al acceder a la URL correspondiente al payload desplegado, se logró obtener una shell remota en el sistema objetivo, confirmando así la explotación exitosa de la vulnerabilidad.

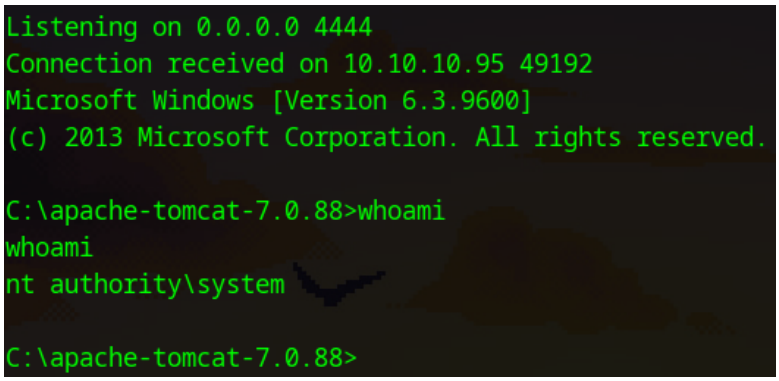

Figura 10: Obtención de shell remota en el sistema objetivo.